



НАЦИОНАЛЬНЫЙ
СТАНДАРТ
РОССИЙСКОЙ
ФЕДЕРАЦИИ

ГОСТ Р
ИСО/МЭК 27018—
2020

Информационные технологии

**МЕТОДЫ И СРЕДСТВА ОБЕСПЕЧЕНИЯ
БЕЗОПАСНОСТИ**

**Свод правил по защите персональных данных (ПДн)
в публичных облаках, используемых
для их обработки**

(ISO/IEC 27018:2019, Information technology — Security techniques —
Code of practice for protection of personally identifiable information (PII) in public
clouds acting as PII processors, IDT)

Издание официальное



Москва
Стандартинформ
2020

Предисловие

1 ПОДГОТОВЛЕН Федеральным государственным учреждением «Федеральный исследовательский центр «Информатика и управление» Российской академии наук» (ФИЦ ИУ РАН) и Обществом с ограниченной ответственностью «Информационно-аналитический вычислительный центр» (ООО ИАВЦ) на основе собственного перевода на русский язык англоязычной версии стандарта, указанного в пункте 4

2 ВНЕСЕН Техническим комитетом по стандартизации ТК 022 «Информационные технологии»

3 УТВЕРЖДЕН И ВВЕДЕН В ДЕЙСТВИЕ Приказом Федерального агентства по техническому регулированию и метрологии от 10 ноября 2020 г. № 1042-ст

4 Настоящий стандарт идентичен международному стандарту ИСО/МЭК 27018:2019 «Информационные технологии. Методы обеспечения безопасности. Свод правил по защите персональных данных (ПДн) в публичных облаках, используемых для их обработки» (ISO/IEC 27018:2019 «Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors»).

ИСО/МЭК 27018 разработан подкомитетом ПК 27 «Методы и средства обеспечения безопасности ИТ» Совместного технического комитета СТК 1 «Информационные технологии» Международной организации по стандартизации (ИСО) и Международной электротехнической комиссии (МЭК).

Наименование настоящего стандарта изменено относительно наименования указанного международного стандарта для приведения в соответствие с ГОСТ Р 1.5—2012 (пункт 3.5).

При применении настоящего стандарта рекомендуется использовать вместо ссылочных международных стандартов соответствующие им национальные и межгосударственные стандарты, сведения о которых приведены в дополнительном приложении ДА

5 ВВЕДЕН ВПЕРВЫЕ

6 Некоторые положения международного стандарта, указанного в пункте 4, могут являться объектом патентных прав. ИСО и МЭК не несут ответственности за идентификацию подобных патентных прав

Правила применения настоящего стандарта установлены в статье 26 Федерального закона от 29 июня 2015 г. № 162-ФЗ «О стандартизации в Российской Федерации». Информация об изменениях к настоящему стандарту публикуется в ежегодном (по состоянию на 1 января текущего года) информационном указателе «Национальные стандарты», а официальный текст изменений и поправок — в ежемесячном информационном указателе «Национальные стандарты». В случае пересмотра (замены) или отмены настоящего стандарта соответствующее уведомление будет опубликовано в ближайшем выпуске ежемесячного информационного указателя «Национальные стандарты». Соответствующая информация, уведомление и тексты размещаются также в информационной системе общего пользования — на официальном сайте Федерального агентства по техническому регулированию и метрологии в сети Интернет (www.gost.ru)

© ISO, 2019 — Все права сохраняются
© IEC, 2019 — Все права сохраняются
© Стандартинформ, оформление, 2020

Настоящий стандарт не может быть полностью или частично воспроизведен, тиражирован и распространен в качестве официального издания без разрешения Федерального агентства по техническому регулированию и метрологии

II

Содержание

1 Область применения	1
2 Нормативные ссылки	1
3 Термины и определения	2
4 Общие сведения	3
4.1 Структура стандарта	3
4.2 Категории мер обеспечения информационной безопасности	4
5 Политики информационной безопасности	4
5.1 Руководящие указания в части информационной безопасности	4
6 Организация деятельности по информационной безопасности	5
6.1 Внутренняя организация деятельности по обеспечению информационной безопасности	5
6.2 Мобильные устройства и дистанционная работа	5
7 Безопасность, связанная с персоналом	5
7.1 При приеме на работу	5
7.2 Во время работы	5
7.3 Увольнение и смена места работы	6
8 Менеджмент активов	6
9 Управление доступом	6
9.1 Требование бизнеса по управлению доступом	6
9.2 Процесс управления доступом пользователей	6
9.3 Ответственность пользователей	7
9.4 Управление доступом к системам и приложениям	7
10 Криптография	8
10.1 Криптографическая защита информации	8
11 Физическая безопасность и защита от воздействия окружающей среды	8
11.1 Зоны безопасности	8
11.2 Оборудование	8
12 Безопасность при эксплуатации	9
12.1 Эксплуатационные процедуры и обязанности	9
12.2 Защита от вредоносных программ	9
12.3 Резервное копирование	9
12.4 Регистрация и мониторинг	10
12.5 Контроль программного обеспечения, находящегося в эксплуатации	11
12.6 Менеджмент технических уязвимостей	11
12.7 Особенности аудита информационных систем	11
13 Безопасность коммуникаций	11
13.1 Менеджмент информационной безопасности сетей	11
13.2 Передача информации	11
14 Приобретение, разработка и поддержка систем	12

15	Взаимоотношения с поставщиками	12
16	Менеджмент инцидентов информационной безопасности	12
16.1	Менеджмент инцидентов информационной безопасности и улучшений	12
17	Аспекты информационной безопасности в рамках менеджмента непрерывности деятельности организации	13
18	Соответствие	13
18.1	Соответствие правовым и договорным требованиям	13
18.2	Проверки информационной безопасности	13
	Приложение А (обязательное) Расширенный набор мер обеспечения информационной безопасности обработчика персональных данных публичного облака для защиты персональных данных	14
	Приложение ДА (справочное) Сведения о соответствии ссылочных международных стандартов национальным и межгосударственным стандартам	21
	Библиография	22

Введение

0.1 Предпосылки и контекст

В случаях, когда для обработки персональных данных (ПДн) используются облачные вычисления, поставщик служб облачных вычислений, действующий на основании соответствующего договора с потребителем, должен организовать свои службы таким образом, чтобы требования законодательства и установленных регуляторами правил в области защиты ПДн соблюдались для обоих участников. Распределение конкретных требований и ответственности за их реализацию между участниками зависит от правовой юрисдикции и условий договора между потребителем и поставщиком. Совокупность законов, устанавливающих правила обработки ПДн (в том числе при их сборе, использовании, передаче и уничтожении), часто называют законодательством по защите данных, а ПДн иногда называют личной или персональной информацией. В различных юрисдикциях обязательства, возлагаемые на операторов ПДн, могут заметно отличаться друг от друга, что затрудняет многонациональное ведение бизнеса, предоставляющего службы облачных вычислений.

При использовании служб публичного облака, в котором обработка ПДн осуществляется в интересах и в соответствии с инструкциями потребителя служб облачных вычислений, поставщик служб публичного облака выступает в роли обработчика ПДн. Потребителями служб облачных вычислений (в рамках договорных отношений с обработчиком ПДн публичного облака) могут быть как физические лица (субъекты ПДн), обрабатывающие в облаке свои собственные ПДн, так и организации (операторы ПДн), обрабатывающие ПДн, принадлежащие многим субъектам ПДн. Потребитель служб облачных вычислений может уполномочить одного или многих связанных с ним пользователей на использование служб, доступных ему в рамках договора с обработчиком ПДн публичного облака. Важно, чтобы у потребителя служб облачных вычислений имелись полномочия на обработку и использование ПДн. Потребитель служб облачных вычислений, который одновременно является оператором ПДн, может подпадать под действие более широкой совокупности обязательств, регулирующих защиту ПДн, чем обработчик ПДн публичного облака. Основным признаком, отличающим обработчика ПДн от оператора ПДн, является то, что в процессе обработки ПДн поставщик служб публичного облака (обработчик ПДн) не имеет никаких других целей и не выполняет никаких других операций, кроме установленных потребителем служб облачных вычислений (оператором ПДн) для решения своих задач.

Примечание — При обработке учетных данных потребителя служб облачных вычислений обработчик ПДн публичного облака может выступать в качестве оператора ПДн. Особенности такого варианта распределения ответственности не являются предметом рассмотрения настоящего стандарта.

Цель настоящего стандарта, при его совместном использовании с целями, мерами обеспечения информационной безопасности (ИБ) ИСО/МЭК 27002, состоит в создании единой совокупности категорий, мер обеспечения ИБ, которые могут быть реализованы поставщиком служб публичного облака, выступающим в качестве обработчика ПДн. Эта цель имеет следующие задачи:

- помочь поставщику служб публичного облака соответствовать применимым обязательствам, если он выступает в качестве обработчика ПДн, и такие обязательства возлагаются на обработчика ПДн в законах, подзаконных нормативных правовых актах и договорных соглашениях;
- обеспечить открытость информации об обработчике ПДн публичного облака в соответствующих вопросах, чтобы потребители служб облачных вычислений могли выбрать хорошо управляемые, основанные на облачных вычислениях службы обработки ПДн;
- помочь потребителю служб облачных вычислений и обработчику ПДн публичного облака составить договорное соглашение;
- предоставить потребителям облачных служб методику для реализации прав и обязанностей по аудиту и соответствию требованиям в тех случаях, когда отдельный аудит со стороны потребителя облачных служб для данных, размещенных в среде виртуализированных серверов (облаков) с множеством участников, технически нецелесообразен и может увеличить риски для применяемых мер обеспечения ИБ физических и логических сетей.

Настоящий стандарт не заменяет действующих законов и норм и является методической основой для проверки на соответствие поставщика служб публичных облаков, в частности для тех поставщиков, которые ведут свой бизнес на многонациональном рынке.

0.2 Меры защиты персональных данных при использовании служб облачных вычислений в публичных облаках

Настоящий стандарт разработан для использования организациями в качестве справочника при выборе мер защиты ПДн в процессе реализации системы менеджмента ИБ облачных вычислений на основе ИСО/МЭК 27001, а также в качестве рекомендаций по реализации общепринятых мер защиты ПДн для организаций, выступающих в качестве обработчиков ПДн публичного облака. В частности, настоящий стандарт основан на требованиях ИСО/МЭК 27002 с учетом специфической среды (сред) риска, возникающей из тех требований по защите ПДн, которые могут быть применимы к поставщикам служб публичных облаков, выступающим в качестве обработчика ПДн.

Обычно организация, обеспечивающая выполнение требований ИСО/МЭК 27001, защищает свои собственные информационные активы. Однако в контексте требований по защите ПДн для поставщика служб публичного облака, выступающего в качестве обработчика ПДн, организация защищает информационные активы, доверенные ей ее потребителями. В этой ситуации применение обработчиком ПДн публичного облака мер обеспечения ИБ из ИСО/МЭК 27002 не только оправданно, но и необходимо. Настоящий стандарт дополняет ИСО/МЭК 27002 мерами обеспечения ИБ, которые учитывают распределенную природу риска и существование договорных отношений между потребителем служб облачных вычислений и обработчиком ПДн публичного облака. Настоящий стандарт дополняет ИСО/МЭК 27002 двумя способами:

- руководство по реализации, применимое к защите ПДн в публичных облаках, предусмотрено лишь для некоторых из существующих мер обеспечения ИБ из ИСО/МЭК 27002;
- приложение А содержит ряд дополнительных мер обеспечения ИБ, не вошедших в существующий набор мер обеспечения ИБ из ИСО/МЭК 27002, и соответствующее руководство, предназначенное для соблюдения требований по защите ПДн в публичных облаках.

Большинство мер обеспечения ИБ и руководство настоящего стандарта будут также применимы к оператору ПДн. Однако на оператора ПДн в большинстве случаев будут возлагаться дополнительные обязательства, не установленные в настоящем стандарте.

0.3 Требования по защите персональных данных

Важно, чтобы организация установила свои требования по защите ПДн. Существует три основных источника требований:

а) законы, подзаконные нормативные правовые акты, договорные соглашения. Первый источник — это правовые, законодательные, установленные операторами и договором требования, которые должны соблюдаться организацией, ее торговыми партнерами, подрядчиками и поставщиками, а также их социокультурная ответственность и среда ведения бизнеса. Следует отметить, что законы, нормы и договорные обязательства, взятые на себя обработчиком ПДн, могут устанавливать требования к выбору определенных мер обеспечения ИБ и сделать обязательными определенные критерии реализации этих мер обеспечения ИБ. Такие требования могут меняться от одной юрисдикции к другой;

б) риски. Второй источник требований получен из оценки рисков, связанных с ПДн, с учетом бизнес-стратегии и целей организации. В рамках оценки рисков идентифицируются угрозы и уязвимости и оцениваются вероятности их реализации и потенциальные последствия. Руководство по управлению рисками ИБ, включая рекомендации по оценке, принятию, коммуникации, мониторингу и пересмотру рисков, приведено в ИСО/МЭК 27005. Руководство по оценке воздействия на конфиденциальность (тайну личной жизни, приватность) приведено в ИСО/МЭК 29134;

с) корпоративные политики — третий источник требований. В то время как многие аспекты, содержащиеся в корпоративной политике, получены на основании правовых и социокультурных обязательств, организация может принять решение добровольно расширить требования перечисления а).

0.4 Выбор и реализация мер обеспечения информационной безопасности в среде облачных вычислений

Меры обеспечения ИБ могут быть выбраны из настоящего стандарта (который включает в себя ссылку на меры обеспечения ИБ из ИСО/МЭК 27002, создающего объединенную справочную совокупность мер обеспечения ИБ для данной области или приложения, определенного в области применения). При необходимости меры обеспечения ИБ могут быть выбраны из других наборов мер обеспече-

ния ИБ, а для удовлетворения соответствующих специфических потребностей могут быть разработаны новые меры обеспечения ИБ.

Примечание — Службы обработки ПДн, предоставляемые обработчиком ПДн публичного облака, могут рассматриваться как приложение облачных вычислений, а не как самостоятельный сектор (отрасль). Тем не менее в настоящем стандарте использован термин «с учетом специфики данной отрасли», поскольку это стандартный термин, используемый в других стандартах серии ИСО/МЭК 27000.

Выбор мер обеспечения ИБ зависит от решений организации, основанных на критериях принятия рисков, вариантах обработки рисков и общем подходе к управлению рисками, примененному к организации и, через договорные соглашения, к ее потребителям и поставщикам, а также должен согласовываться со всеми соответствующими применимыми национальными и международными законами и нормами. Если меры обеспечения ИБ из настоящего стандарта не выбраны, то это должно быть задокументировано с обоснованием причин.

Кроме того, выбор и реализация мер обеспечения ИБ зависят от фактической роли поставщика публичного облака в контексте всей эталонной архитектуры облачных вычислений (см. ИСО/МЭК 17789). В поддержание инфраструктурных служб и приложений в среде облачных вычислений может быть вовлечено много различных организаций. В некоторых случаях выбранные меры обеспечения ИБ могут быть уникальны для определенной категории служб эталонной архитектуры облачных вычислений. В других случаях при реализации мер обеспечения ИБ могут существовать общие роли. Договорные соглашения должны определять обязанности по защите ПДн всех организаций, вовлеченных в поддержание или использование служб облачных вычислений, включая обработчика ПДн публичного облака, его субподрядчиков и потребителя служб облачных вычислений.

Меры обеспечения ИБ, описанные в настоящем стандарте, можно считать руководящими принципами и применимыми для большинства организаций. Такие меры обеспечения ИБ, а также руководство по их реализации подробно рассмотрены в настоящем стандарте. Реализация может быть упрощена, если требования по защите ПДн были учтены на стадии проектирования информационных систем, служб и работ обработчика ПДн публичного облака. Данное соображение является элементом концепции, часто называемой «спроектированная защита данных». Соответствующие документы приведены в библиографии (см. [19]).

0.5 Разработка дополнительных рекомендаций

Настоящий стандарт может рассматриваться как основа для разработки рекомендаций по защите ПДн. Не все меры обеспечения ИБ и руководство из данного свода правил могут быть применимы. Более того, могут потребоваться дополнительные меры обеспечения ИБ и рекомендации, не вошедшие в настоящий стандарт. При разработке документов, содержащих дополнительные рекомендации или меры обеспечения ИБ, в соответствующих местах будет полезным вставить перекрестные ссылки на пункты настоящего стандарта, что упростит проверку соответствия аудиторами и бизнес-партнерами.

0.6 Жизненный цикл персональных данных

У ПДн имеется естественный жизненный цикл — от создания через хранение, обработку, использование и передачу к окончательному разрушению или уничтожению. Риски для ПДн могут изменяться в течение всего времени их жизни, но защита ПДн должна обеспечиваться на всех этапах жизненного цикла.

Требования по защите ПДн должны учитываться на всех этапах жизненного цикла существующих и вновь создаваемых информационных систем.

Информационные технологии

МЕТОДЫ И СРЕДСТВА ОБЕСПЕЧЕНИЯ БЕЗОПАСНОСТИ

Свод правил по защите персональных данных (ПДн)
в публичных облаках, используемых для их обработки

Information technology. Security techniques and tools. Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors

Дата введения — 2021—06—01

1 Область применения

Настоящий стандарт устанавливает общепринятые цели, меры обеспечения информационной безопасности (ИБ) и рекомендации по реализации мер защиты персональных данных (ПДн) в соответствии с правилами конфиденциальности ИСО/МЭК 29100 для вычислительной среды публичных облаков.

В частности, настоящий стандарт определяет рекомендации, основываясь на ИСО/МЭК 27002 и учитывая нормативные требования по защите ПДн, которые могут быть применимы в контексте рисков ИБ для поставщика служб публичных облаков.

Настоящий стандарт применим к организациям всех типов и размеров, включая публичные и частные компании, государственные и некоммерческие организации, предоставляющим службы обработки информации в качестве обработчиков ПДн на основе облачных вычислений в соответствии с договором с другими организациями.

Рекомендации настоящего стандарта могут относиться к организациям, выступающим в качестве операторов ПДн; однако на операторов ПДн могут распространяться дополнительные законы, нормы и обязательства по защите ПДн, не применимые к обработчикам ПДн. Настоящий стандарт не предназначен для рассмотрения дополнительных обязательств.

2 Нормативные ссылки

В настоящем стандарте использованы следующие нормативные ссылки. для датированных ссылок применяют только указанное издание ссылочного стандарта, для недатированных — последнее издание (включая все изменения):

ISO/IEC 17788, Information technology — Cloud computing — Overview and Vocabulary (Информационная технология. Облачные вычисления. Общие положения и терминология)

ISO/IEC 27000, Information technology — Security techniques — Information security management systems — Overview and vocabulary (Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Общие положения и терминология)

ISO/IEC 27002:2013, Information technology — Security techniques — Code of practice for information security controls (Информационная технология. Методы и средства обеспечения безопасности. Свод правил для мер и средств контроля и управления информационной безопасностью)

3 Термины и определения

В настоящем стандарте применены термины по ИСО/МЭК 17788 и ИСО/МЭК 27000, а также следующие термины с соответствующими определениями.

С целью использования в стандартах ИСО и МЭК поддерживают терминологические базы данных:

- платформа ИСО для онлайн-просмотра: доступна по адресу <http://www.iso.org/obp>
- МЭК Электропедия (IEC Electropedia): доступна по адресу <http://www.electropedia.org/>

3.1

компрометация данных (data breach): Нарушение безопасности, которое приводит к случайному или незаконному разрушению, потере, изменению, несанкционированному раскрытию или доступу к защищаемым данным, передаваемым, хранимым или иным образом обрабатываемым.
[ИСО/МЭК 27040:2015, статья 3.7]

3.2

персональные данные (ПДн) (personally identifiable information, PII): Любая информация, которая (а) может быть использована для идентификации субъекта ПДн, к которому она относится, или (b) прямо или косвенно может быть связана с ним.

Примечания

1 Под термином «физическое лицо» в данном определении подразумевается «субъект ПДн» (3.4). Чтобы определить, является ли субъект ПДн идентифицируемым, необходимо рассмотреть/оценить все разумные возможности, которые могут быть использованы стороной, хранящей данные, или любой другой стороной, чтобы установить связь между набором ПДн и физическим лицом.

2 Данное определение введено для понимания термина ПДн, используемого в документе. Обработчик ПДн публичного облака (3.5) зачастую не в состоянии самостоятельно определить, к какой категории может относиться обрабатываемая им информация, если это не раскроет потребитель облачных служб.

[ИСО/МЭК 29100:2011, статья 2.9, измененная — к определению было добавлено примечание 2]

3.3

оператор ПДн (PII controller): Сторона (или стороны), которая определяет цели и средства обработки персональных данных (ПДн) (3.2), кроме физических лиц, использующих ПДн в личных целях.

Примечание — Оператор ПДн может поручать обработку ПДн другим сторонам [например, обработчикам ПДн (3.5)], при этом ответственность за использование персональных данных в целом остается за оператором ПДн.

[ИСО/МЭК 29100:2011, статья 2.10]

3.4

субъект ПДн (PII principal): Физическое лицо, к которому относятся персональные данные (ПДн) (3.2).

Примечание — В зависимости от юрисдикции и особенностей законодательства в области защиты ПДн вместо термина «субъект ПДн» может также использоваться его синоним «субъект данных».

[ИСО/МЭК 29100:2011, статья 2.11]

3.5

обработчик ПДн (PII processor): Сторона, отвечающая за обработку персональных данных (ПДн) (3.2) от лица оператора (3.3) ПДн в соответствии с его предписаниями.

[ИСО/МЭК 29100:2011, статья 2.12]

3.6

обработка ПДн (processing of PII): Действие или набор действий, выполняемые с персональными данными (ПДн) (3.2).

Примечание — Примеры операций включают в себя (но не ограничиваются этим) сбор, хранение, изменение, восстановление, опрос, разглашение, обезличивание, псевдонимизацию, распространение или иное предоставление, удаление или уничтожение ПДн.

[ИСО/МЭК 29100:2011, статья 2.23]

3.7 поставщик служб публичного облака (public cloud service provider): Сторона, которая предоставляет службы облачных вычислений в соответствии с моделью публичного облака.

4 Общие сведения

4.1 Структура стандарта

Настоящий стандарт имеет структуру, схожую со структурой ИСО/МЭК 27002. В случаях, когда определенные в ИСО/МЭК 27002 цели, меры обеспечения ИБ применимы напрямую, без каких-либо дополнительных особенностей, дается ссылка на ИСО/МЭК 27002. Дополнительные меры обеспечения ИБ и соответствующие им рекомендации по реализации, применимые к защите ПДн поставщиками служб облачных вычислений, приведены в приложении А.

В случаях, когда для мер обеспечения ИБ требуется дополнительное руководство, применимое к защите ПДн поставщиками служб облачных вычислений, оно приведено под заголовком «Рекомендации по реализации мер защиты персональных данных в публичных облаках». В ряде случаев соответствующая информация, усиливающая дополнительное руководство, приведена под заголовком «Другая информация по защите персональных данных в публичных облаках».

Как показано в таблице 1, специфичное для данной отрасли руководство по реализации и другая информация включены в определенные в ИСО/МЭК 27002 категории. Номера пунктов, указанные в таблице, приведены в соответствии с номерами пунктов в ИСО/МЭК 27002.

Настоящий стандарт должен использоваться вместе с ИСО/МЭК 27001, и применение дополнительных мер обеспечения ИБ, определенных в приложении А, должно рассматриваться как часть процесса внедрения Системы менеджмента ИБ на основе 27001.

Таблица 1 — Место специфичного для данной отрасли руководства и другой информации по реализации мер обеспечения ИБ из ИСО/МЭК 27002

Номер раздела	Категория мер обеспечения ИБ	Комментарии
5	Политики информационной безопасности	Предоставлено специфичное для данной области руководство по реализации и другая информация.
6	Организация деятельности по информационной безопасности	Предоставлено специфичное для данной области руководство по реализации.
7	Безопасность, связанная с персоналом	Предоставлено специфичное для данной области руководство по реализации и другая информация.
8	Менеджмент активов	Не предоставлено никакого специфичного для данной области руководства по реализации и другой информации.
9	Управление доступом	Предоставлено специфичное для данной области руководство по реализации вместе с перекрестной ссылкой на средство(а) управления в приложении А.
10	Криптография	Предоставлено специфичное для данной области руководство по реализации.
11	Физическая безопасность и защита от воздействия окружающей среды	Предоставлено специфичное для данной области руководство по реализации вместе с перекрестной ссылкой на средство(а) управления в приложении А.
12	Безопасность при эксплуатации	Предоставлено специфичное для данной области руководство по реализации.
13	Безопасность систем связи	Предоставлено специфичное для данной области руководство по реализации вместе с перекрестной ссылкой на средство(а) управления в приложении А.
14	Приобретение, разработка и поддержка систем	Не предоставлено никакого специфичного для данной области руководства по реализации и другой информации.

Окончание таблицы 1

Номер раздела	Категория мер обеспечения ИБ	Комментарии
15	Взаимоотношения с поставщиками	Не предоставлено никакого специфичного для данной области руководства по реализации и другой информации.
16	Менеджмент инцидентов информационной безопасности	Предоставлено специфичное для данной области руководство по реализации.
17	Аспекты информационной безопасности в рамках менеджмента непрерывности деятельности организации	Не предоставлено никакого специфичного для данной области руководства по реализации и другой информации.
18	Соответствие	Предоставлено специфичное для данной области руководство по реализации вместе с перекрестной ссылкой на средство(а) управления в приложении А.

4.2 Категории мер обеспечения информационной безопасности

В соответствии с ИСО/МЭК 27002 каждая основная категория мер обеспечения ИБ содержит:

- а) утверждение цели управления, которая должна быть достигнута;
- б) одну или более мер обеспечения ИБ, которые могут быть применены для достижения цели управления.

Описания мер обеспечения ИБ структурированы следующим образом:

Мера обеспечения информационной безопасности

Формулирует специфическую меру обеспечения ИБ, отвечающую цели управления.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Предоставляют подробную информацию для поддержки реализации меры обеспечения ИБ и достижения целей управления. Рекомендации могут подойти не полностью или быть недостаточными для всех ситуаций, а также могут не включать определенные требования организации к мере обеспечения ИБ. В таком случае могут подойти альтернативные или дополнительные меры обеспечения ИБ или другие способы обработки риска (избежание, передача или принятие рисков).

Другая информация по защите персональных данных в публичных облаках

Предоставляет дополнительную информацию, которую, возможно, потребуется рассмотреть, например, правовые соображения и ссылки на другие стандарты.

5 Политики информационной безопасности

5.1 Руководящие указания в части информационной безопасности

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 5.1).

5.1.1 Политики информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 5.1.1). Также применяются следующие специфичные для данной области рекомендации.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Политики ИБ должны быть дополнены выражением поддержки и обязательством достигнуть соответствия с применимым законодательством по защите ПДн и договорными условиями, согласованными между обработчиком ПДн публичного облака и его клиентами (потребителями служб облачных вычислений).

Договорные соглашения должны четко распределять обязанности между обработчиком ПДн публичного облака, его субподрядчиками и потребителем служб облачных вычислений, приняв во внимание тип рассматриваемой службы облачных вычислений (например, категории служб IaaS, PaaS или SaaS эталонной архитектуры облачных вычислений). Например, распределение обязанностей по

мерам обеспечения ИБ прикладного уровня может отличаться в зависимости от того, предоставляет ли обработчик ПДн публичного облака службу SaaS или отдает предпочтение службе PaaS или IaaS, на основе которого потребитель служб облачных вычислений может создать или разделить по уровням свои собственные приложения.

Другая информация по защите персональных данных в публичных облаках

В некоторых юрисдикциях обработчик ПДн публичного облака непосредственно подпадает под действие законодательства по защите ПДн. В других случаях законодательство по защите ПДн применяется только по отношению к оператору ПДн.

Механизм, обеспечивающий обязанность обработчика ПДн публичного облака поддерживать и управлять соответствием требованиям, предусматривается договором между потребителем служб облачных вычислений и обработчиком ПДн публичного облака. Договор может требовать оцениваемого во время независимой проверки соответствия, приемлемого для потребителя служб облачных вычислений, например, посредством реализации соответствующих мер обеспечения ИБ по настоящему стандарту и ИСО/МЭК 27002.

5.1.2 Пересмотр политик информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 5.1.2).

6 Организация деятельности по информационной безопасности

6.1 Внутренняя организация деятельности по обеспечению информационной безопасности

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 6.1).

6.1.1 Роли и обязанности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 6.1.1). Также применяются следующие специфичные для данной области рекомендации.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Обработчик ПДн публичного облака должен обозначить потребителю облачных служб контактное лицо для взаимодействия по вопросам обработки ПДн, осуществляемой по договору.

6.1.2 Разделение обязанностей

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 6.1.2).

6.1.3 Взаимодействие с органами власти

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 6.1.3).

6.1.4 Взаимодействие с профессиональными сообществами

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 6.1.4).

6.1.5 Информационная безопасность при управлении проектами

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 6.1.5).

6.2 Мобильные устройства и дистанционная работа

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 6.2).

7 Безопасность, связанная с персоналом

7.1 При приеме на работу

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 7.1).

7.2 Во время работы

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 7.2).

7.2.1 Обязанности руководства организации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 7.2.1).

7.2.2 Осведомленность, обучение и практическая подготовка (тренинги) в области информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 7.2.2). Также применяются следующие специфические для данной области рекомендации.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Должны быть приняты необходимые меры по уведомлению соответствующих лиц о возможных последствиях нарушения конфиденциальности или правил безопасности: для обработчика ПДн публичного облака (например, о правовых последствиях, возможности потери бизнеса или бренда, возникновении ущерба для репутации), штатного сотрудника (например, о дисциплинарных последствиях) и субъекта ПДн (например, о физических, материальных и моральных последствиях) и процедурах, особенно тех, которые задействованы при обработке ПДн.

Другая информация по защите персональных данных в публичных облаках

В некоторых юрисдикциях обработчик ПДн публичного облака может подпадать под правовые санкции, включая существенные штрафы непосредственно от локальных инстанций по защите ПДн. В других юрисдикциях при согласовании между обработчиком ПДн публичного облака и потребителем служб облачных вычислений использование таких стандартов, как настоящий, должно помочь создать основу для договорных санкций за нарушение правил и процедур безопасности.

7.2.3 Дисциплинарный процесс

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 7.2.3).

7.3 Увольнение и смена места работы

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 7.3).

8 Менеджмент активов

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (раздел 8).

9 Управление доступом

9.1 Требование бизнеса по управлению доступом

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 9.1).

9.2 Процесс управления доступом пользователей

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 9.2).

Кроме того, применяются следующие специфические для данной области рекомендации по реализации всех мер обеспечения ИБ.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В контексте категорий служб эталонной архитектуры облачных вычислений потребитель служб облачных вычислений может нести ответственность за некоторые или все аспекты управления доступом пользователей служб облачных вычислений, входящих в зону его управления. В случае необходимости обработчик ПДн публичного облака должен разрешить потребителю служб облачных вычислений управлять доступом пользователей служб облачных вычислений, входящих в зону управления потребителя служб облачных вычислений, например, предоставив административные права для управления или прекращения доступа.

9.2.1 Регистрация и отмена регистрации пользователей

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.2.1). Также применяются следующие специфические для данной области рекомендации.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Процедуры регистрации и снятия с учета пользователя должны предусматривать случаи, когда управление доступом пользователей нарушено, например, повреждены или скомпрометированы пароли или другие регистрационные данные пользователя (например, в результате непреднамеренного раскрытия).

Примечание — Отдельные юрисдикции могут налагать специальные требования на частоту проверок наличия неиспользуемых аутентификационных учетных данных. Организации, работающие в этих юрисдикциях, должны гарантировать, что они соответствуют этим требованиям.

9.2.2 Предоставление пользователю права доступа

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.2.2).

9.2.3 Управление привилегированными правами доступа

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.2.3).

9.2.4 Процесс управления секретной аутентификационной информацией пользователей

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.2.4).

9.2.5 Пересмотр прав доступа пользователей

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.2.5).

9.2.6 Аннулирование и корректировка прав доступа

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.2.6).

9.3 Ответственность пользователей

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 9.3).

9.3.1 Использование секретной аутентификационной информации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 9.3.1).

9.4 Управление доступом к системам и приложениям

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 9.4).

9.4.1 Ограничение доступа к информации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.4.1).

Примечание — Дополнительные меры обеспечения ИБ и рекомендации, относящиеся к ограничению доступа к информации, можно найти в A.11.13.

9.4.2 Безопасные процедуры входа в систему

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.4.2). Также применяется следующая специфичная для данной области рекомендация: в случае необходимости обработчик ПДн публичного облака должен обеспечить безопасные процедуры входа в систему для любых учетных записей, указанных потребителем служб облачных вычислений для пользователей служб облачных вычислений, входящих в зону его управления.

9.4.3 Система управления паролями

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.4.3).

9.4.4 Использование привилегированных служебных программ

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.4.4).

9.4.5 Управление доступом к исходному тексту программы

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 9.4.5).

10 Криптография

10.1 Криптографическая защита информации

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 10.1).

10.1.1 Политика использования средств криптографической защиты информации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 10.1.1). Также применяется следующая специфичная для данной области рекомендация: обработчик ПДн публичного облака должен предоставить потребителю служб облачных вычислений информацию об обстоятельствах, при которых для защиты обрабатываемых им ПДн используются средства криптографической защиты информации. Обработчик ПДн публичного облака должен также предоставить потребителю служб облачных вычислений информацию о любых предоставляемых им возможностях, способных помочь потребителю служб облачных вычислений в применении его собственной криптографической защиты.

Примечание — В некоторых юрисдикциях для защиты определенных видов ПДн, таких как медицинские данные, относящиеся к субъекту ПДн, регистрационные номера резидента (жителей, граждан), номера паспорта и водительских прав, может потребоваться применить криптографию.

10.1.2 Управление ключами

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 10.1.2).

11 Физическая безопасность и защита от воздействия окружающей среды

11.1 Зоны безопасности

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 11.1).

11.2 Оборудование

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 11.2).

11.2.1 Размещение и защита оборудования

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 11.2.1).

11.2.2 Вспомогательные услуги

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 11.2.2).

11.2.3 Безопасность кабельной сети

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 11.2.3).

11.2.4 Техническое обслуживание оборудования

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 11.2.4).

11.2.5 Перемещение активов

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 11.2.5).

11.2.6 Безопасность оборудования и активов вне помещений организации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 11.2.6).

11.2.7 Безопасная утилизация или повторное использование оборудования

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 11.2.7). Также применяется следующая специфичная для данной области рекомендация: в целях безопасной утилизации или повторного использования в отношении оборудования с носителями, потенциально содержащими ПДн, должны применяться те же меры, как и в отношении оборудования, содержащего ПДн.

Примечание — Дополнительные меры обеспечения ИБ и рекомендации по безопасной утилизации или повторному использованию оборудования можно найти в А.10.3.

11.2.8 Оборудование, оставленное пользователем без присмотра

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 11.2.8).

11.2.9 Политика «чистого стола» и «чистого экрана»

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 11.2.9).

12 Безопасность при эксплуатации

12.1 Эксплуатационные процедуры и обязанности

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 12.1).

12.1.1 Документально оформленные эксплуатационные процедуры

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 12.1.1).

12.1.2 Процесс управления изменениями

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 12.1.2).

12.1.3 Управление производительностью

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации и другая информация, определенные в ИСО/МЭК 27002 (см. 12.1.3).

12.1.4 Разделение сред разработки, тестирования и эксплуатации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 12.1.4). Также применяется следующая специфичная для данной области рекомендация: если использования ПДн для целей тестирования избежать нельзя, то должна быть проведена оценка рисков. Для минимизации идентифицированных рисков должны быть реализованы технические и организационные меры.

12.2 Защита от вредоносных программ

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 12.2).

12.3 Резервное копирование

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 12.3).

12.3.1 Резервное копирование информации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 12.3.1). Также применяется следующая специфичная для данной области рекомендация: системы обработки информации, основанные на модели облачных вычислений, предоставляют дополнительные или альтернативные средства удаленного резервного копирования для защиты от потери данных, обеспечения непрерывности операций обработки данных и поддержки возможности восстановить операции обработки данных после события прерывания. В целях резервного копирования и/или восстановления должны создаваться или поддерживаться множественные копии данных в физически и/или логически разнесенных локациях (которые могут находиться в самой системе обработки информации).

В этой связи на потребителя служб облачных вычислений могут лежать специфические обязанности по защите ПДн. Если обработчик ПДн публичного облака явно предоставляет потребителю служб облачных вычислений резервное копирование и службы по восстановлению, то обработчик ПДн публичного облака должен предоставлять и понятную потребителю служб облачных вычислений информацию о возможностях служб по резервному копированию и восстановлению данных потребителя служб облачных вычислений.

Примечание — Отдельные юрисдикции могут предъявлять специальные требования к частоте резервного копирования. Организации, работающие в этих юрисдикциях, должны гарантировать соответствие этим требованиям.

Должны существовать соответствующие процедуры, позволяющие восстанавливать операции по обработке данных в течение указанного, документально зафиксированного периода после события прерывания.

Процедуры резервного копирования и восстановления должны пересматриваться с указанной, документально зафиксированной частотой.

Примечание — Отдельные юрисдикции могут предъявлять специальные требования к частоте пересмотра процедур восстановления и резервного копирования. Организации, работающие в этих юрисдикциях, должны гарантировать соответствие этим требованиям.

Привлечение субподрядчиков для хранения тиражированных или резервных копий обработанных данных обеспечивается мерами обеспечения ИБ настоящего стандарта, применяющегося к обработке ПДн субподрядчиками. Меры обеспечения ИБ настоящего стандарта также распространяются на случаи, когда имеет место передача на физических носителях.

Обработчик ПДн публичного облака должен иметь политику, содержащую требования к резервному копированию информации и любые другие требования (например, требования договоров и/или законодательства) по уничтожению ПДн, содержащихся в информации, хранимой для целей резервного копирования.

12.4 Регистрация и мониторинг

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 12.4).

12.4.1 Регистрация событий

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 12.4.1). Также применяется следующая специфичная для данной области рекомендация: для идентификации неисправностей и выработки предложений по их устранению должен существовать соответствующий процесс рассмотрения журналов событий с указанной, документально зафиксированной периодичностью.

Где это возможно, журналы событий должны фиксировать, были ли ПДн изменены или нет (добавлены, изменены или удалены) в результате какого-либо события и кем. Если в предоставление служб различных категорий служб эталонной архитектуры облачных вычислений вовлечены несколько поставщиков служб, то роли по реализации этих рекомендаций могут меняться или исполняться совместно.

Обработчик ПДн публичного облака должен определить условия, при которых потребителю служб облачных вычислений разрешен доступ к записям журнала регистрации событий. Процедуры доступа должны быть реализованы для потребителя служб облачных вычислений.

Если потребителю служб облачных вычислений разрешен доступ к записям журнала регистрации, управляемого обработчиком ПДн публичного облака, то обработчик ПДн публичного облака должен гарантировать, что потребитель служб облачных вычислений может получить доступ только к тем записям, которые касаются действий этого потребителя служб облачных вычислений, и не может получить доступ ни к каким записям журнала, которые касаются действий других потребителей, служб облачных вычислений.

12.4.2 Защита информации регистрационных журналов

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 12.4.2). Также применяется следующая специфичная для данной области рекомендация: информация из журнала, записанная в таких целях, как мониторинг безопасности и диагностика операций, может содержать ПДн. Должны существовать

соответствующие меры, такие как управление доступом (см. 9.2.3), гарантирующие, что зарегистрированная информация используется только в намеченных целях.

Должна существовать соответствующая процедура, предпочтительно автоматизированная, обеспечивающая удаление зарегистрированной информации в течение указанного и документально зафиксированного периода.

12.4.3 Регистрационные журналы действий администратора и оператора

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 12.4.3).

12.4.4 Синхронизация часов

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 12.4.4).

12.5 Контроль программного обеспечения, находящегося в эксплуатации

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 12.5).

12.6 Менеджмент технических уязвимостей

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 12.6).

12.7 Особенности аудита информационных систем

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 12.7).

13 Безопасность коммуникаций

13.1 Менеджмент информационной безопасности сетей

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 13.1).

13.2 Передача информации

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 13.2).

13.2.1 Политики и процедуры передачи информации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 13.2.1). Также применяется следующая специфичная для данной области рекомендация: в случае если для передачи информации используются физические носители информации, то должны быть приняты меры по регистрации входящих и исходящих физических носителей, содержащих ПДн, включая тип физического носителя, авторизованного отправителя/получателя, дату, время и количество физических носителей. Если это возможно, то потребителей служб облачных вычислений необходимо попросить применять соответствующие дополнительные меры (такие как шифрование), обеспечивающие возможность получения доступа к данным только в месте назначения, а не на пути к нему.

13.2.2 Соглашения о передаче информации

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 13.2.2).

13.2.3 Электронный обмен сообщениями

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 13.2.3).

13.2.4 Соглашения о конфиденциальности или неразглашении

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 13.2.4).

Примечание — Дополнительные меры обеспечения ИБ и рекомендации по соглашениям о конфиденциальности или неразглашении можно найти в А.10.1.

14 Приобретение, разработка и поддержка систем

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 14).

15 Взаимоотношения с поставщиками

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 15).

Примечание — Дополнительная информация по управлению взаимоотношениями с поставщиками может быть получена из ИСО/МЭК 27036-4.

16 Менеджмент инцидентов информационной безопасности

16.1 Менеджмент инцидентов информационной безопасности и улучшений

Применяется цель, определенная в ИСО/МЭК 27002:2013 (см. 16.1). В соответствии с данным подразделом также применяется следующая специфичная для данной области рекомендация по реализации всех мер обеспечения ИБ: в контексте всей эталонной архитектуры облачных вычислений могут существовать общие роли по менеджменту инцидентов ИБ и его совершенствованию. При реализации мер обеспечения ИБ данного подпункта от обработчика ПДн публичного облака может потребоваться сотрудничество с потребителем служб облачных вычислений.

16.1.1 Обязанности и процедуры

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 16.1.1). Также применяются следующие специфичные для данной области рекомендации.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

1. Для определения того, имела ли место компрометация данных, содержащих ПДн (см. А.10.1), инцидент ИБ должен быть рассмотрен обработчиком ПДн публичного облака в рамках процедур управления инцидентами ИБ.

2. Не всякое событие ИБ должно приводить к такому рассмотрению, так как не всякое событие ИБ свидетельствует о фактическом или (с определенной вероятностью) несанкционированном доступе к ПДн или какому-либо оборудованию или средству обработчика ПДн публичного облака, хранящему ПДн. В частности, среди таких событий можно перечислить такие, как пингование и другие широковебательные атаки на межсетевые экраны или граничные серверы, сканирования портов, неуспешные попытки входа в систему, атаки типа «отказ в обслуживании» и прослушивание (сниффинг) пакетов.

16.1.2 Сообщения о событиях информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 16.1.2).

16.1.3 Сообщения о недостатках информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 16.1.3).

16.1.4 Оценка и принятие решения в отношении событий информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, определенные в ИСО/МЭК 27002 (см. 16.1.4).

16.1.5 Реагирование на инциденты информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 16.1.5).

16.1.6 Анализ инцидентов информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 16.1.6).

16.1.7 Сбор свидетельств

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 16.1.7).

17 Аспекты информационной безопасности в рамках менеджмента непрерывности деятельности организации

Применяются цель и содержание согласно ИСО/МЭК 27002:2013 (см. 17).

18 Соответствие**18.1 Соответствие правовым и договорным требованиям**

Применяются цель и содержание согласно ИСО/МЭК 27002 (см. 18.1).

Примечание — Дополнительные меры обеспечения ИБ и рекомендации, относящиеся к соответствию требованиям законодательства и договоров, можно найти в А. 11.

18.2 Проверки информационной безопасности

Применяется цель, определенная согласно ИСО/МЭК 27002:2013 (см. 18.2).

18.2.1 Независимая проверка информационной безопасности

Применяются меры обеспечения ИБ и соответствующие им рекомендации по реализации, а также другая информация, определенные в ИСО/МЭК 27002 (см. 18.2.1). Также применяется следующая специфичная для данной области рекомендация: в случаях, когда отдельные аудиты потребителя служб облачных вычислений технически неосуществимы или могут увеличить риски для безопасности (см. 0.1), обработчик ПДн публичного облака должен предоставлять потенциальным потребителям служб облачных вычислений до заключения и на срок действия договора независимые доказательства того, что ИБ реализуется и управляется в соответствии с политиками и процедурами обработчика ПДн публичного облака. По выбору обработчика ПДн публичного облака соответствующая независимая проверка обычно должна быть пригодной для удовлетворения интереса потребителя служб облачных вычислений в оценке операций обработки обработчика ПДн публичного облака, обеспечивая достаточную прозрачность.

18.2.2 Соответствие политикам и стандартам безопасности

Применяются меры обеспечения ИБ, а также соответствующие им рекомендации по реализации и другая информация, определенные в ИСО/МЭК 27002 (см. 18.2.2).

18.2.3 Анализ технического соответствия

Применяются меры обеспечения ИБ, а также соответствующие им рекомендации по реализации и другая информация, определенные в ИСО/МЭК 27002 (см. 18.2.3).

Приложение А
(обязательное)**Расширенный набор мер обеспечения информационной безопасности обработчика персональных данных публичного облака для защиты персональных данных****А.1 Основные положения**

Данное приложение определяет новые меры обеспечения информационной безопасности (ИБ) и соответствующие рекомендации по их реализации, которые в сочетании с расширенными мерами обеспечения ИБ и рекомендациями из ИСО/МЭК 27002 (см. разделы 5—18) составляют расширенный набор мер обеспечения ИБ, удовлетворяющий требованиям по защите ПДн, применяемым к поставщикам публичного облака, выступающим в качестве обработчиков ПДн.

Такие дополнительные меры обеспечения ИБ классифицируются согласно одиннадцати принципам обеспечения приватности, приведенным в ИСО/МЭК 29100. Во многих случаях меры обеспечения ИБ могут классифицироваться по более чем одному из правил конфиденциальности. В таких случаях они классифицируются по самому подходящему правилу.

А.2 Согласие и возможность выбора**А.2.1 Обязательство сотрудничества в отношении прав субъектов персональных данных****Мера обеспечения информационной безопасности**

Обработчик ПДн публичного облака должен предоставить потребителю служб облачных вычислений средства, позволяющие ему выполнять свои обязательства по содействию субъектам ПДн в получении ими прав доступа, коррекции и/или уничтожения ПДн, имеющих отношение к ним.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В этом отношении обязательства оператора ПДн могут быть определены законами, нормами или договором. Такие обязательства могут включать вопросы использования потребителем служб облачных вычислений служб обработчика ПДн публичного облака для реализации. Например, это может включать своевременную коррекцию или удаление ПДн.

Если в отношении информации или технических мер, упрощающих осуществление прав субъектом ПДн, оператор ПДн зависит от обработчика ПДн публичного облака, в договоре должны быть определены соответствующая информация или технические меры.

А.3 Законность и декларация целей обработки персональных данных**А.3.1 Цель обработчика персональных данных публичного облака****Мера обеспечения информационной безопасности**

ПДн, которые обрабатываются в соответствии с договором, не должны обрабатываться в каких-либо других целях, не предусмотренных предписаниями потребителя служб облачных вычислений.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В договоре между обработчиком ПДн публичного облака и потребителем служб облачных вычислений могут содержаться предписания, включая, например, цели и сроки, которые должны быть достигнуты при использовании служб.

При достижении целей потребителя служб облачных вычислений могут существовать технические причины, почему для обработчика ПДн публичного облака нужно определить метод обработки ПДн, соответствующий общим, но не специальным, предписаниям потребителя служб облачных вычислений. Например, для эффективного использования сети или обрабатывающих мощностей может быть необходимо выделить определенные ресурсы для обработки в зависимости от конкретных характеристик субъекта ПДн. В случае если определенный обработчиком ПДн публичного облака метод обработки включает сбор и использование ПДн, то обработчик ПДн публичного облака должен придерживаться соответствующих правил конфиденциальности, сформулированных в ИСО/МЭК 29100.

Обработчик ПДн публичного облака должен предоставить потребителю служб облачных вычислений всю необходимую информацию своевременно, что позволит потребителю служб облачных вычислений гарантировать соответствие обработчика ПДн публичного облака определенным целям и принципам ограничений и гарантировать, что никакие ПДн не обрабатываются обработчиком ПДн публичного облака или любым из его субподрядчиков для иных целей, не предусмотренных предписаниями потребителя служб облачных вычислений.

А.3.2 Коммерческое использование персональных данных обработчиком персональных данных публичного облака

Мера обеспечения информационной безопасности

ПДн, обрабатываемые в соответствии с договором, не должны использоваться обработчиком ПДн публичного облака в целях маркетинга и рекламы без явно выраженного на это согласия. Такое согласие не должно быть условием получения услуги.

Примечание — Эта мера обеспечения ИБ является дополнением к более общей мере и средству контроля и управления в соответствии с А.3.1 и не заменяет или отменяет ее.

А.4 Ограничение на сбор информации

Никакие дополнительные меры обеспечения ИБ не соответствуют данному правилу конфиденциальности.

А.5 Минимизация данных

А.5.1 Безопасное стирание временных файлов

Мера обеспечения информационной безопасности

Временные файлы и документы должны быть стерты или уничтожены в течение указанного, документально зафиксированного периода.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Руководство по реализации стирания ПДн предоставлено в соответствии с А.10.3.

Информационные системы в ходе нормального функционирования могут создать временные файлы. Такие файлы являются специфичными для системы или приложения, но они могут включать журналы отката файловой системы и временные файлы, связанные с обновлением баз данных и работой другого прикладного программного обеспечения. Временные файлы не нужны после того, как задача обработки соответствующей информации завершена, но существуют обстоятельства, при которых они могут быть не удалены. Отрезок времени, в течение которого эти файлы остаются доступными, не всегда можно определить, но процедура «сборки мусора» должна идентифицировать соответствующие файлы и установить, сколько времени прошло с тех пор, как их использовали в последний раз.

Информационные системы, обрабатывающие ПДн, должны реализовать периодическую проверку того, что не использованные выше указанного срока временные файлы удалены.

А.6 Ограничение использования, хранения и раскрытия

А.6.1 Уведомление о раскрытии персональных данных

Мера обеспечения информационной безопасности

Договор между обработчиком ПДн публичного облака и потребителем служб облачных вычислений должен требовать, чтобы обработчик ПДн публичного облака в соответствии с согласованными в договоре процедурой и сроком уведомлял потребителя служб облачных вычислений о любом юридически предусмотренном запросе на раскрытие ПДн со стороны правоохранительных органов, если такое раскрытие запрещено иным образом.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Обработчик ПДн публичного облака должен обеспечить договорные гарантии того, что он:

- отклонит любые не предусмотренные по закону запросы на раскрытие ПДн;
- проконсультирует соответствующего потребителя служб облачных вычислений, если это юридически допустимо, до раскрытия любых ПДн;
- примет любые согласованные в договоре запросы на раскрытие ПДн, которые санкционированы соответствующим потребителем служб облачных вычислений.

Пример — Примером возможного запрета на раскрытие может быть запрет в соответствии с уголовным правом для сохранения конфиденциальности расследования правоохранительными органами.

А.6.2 Регистрация раскрытия персональных данных

Мера обеспечения информационной безопасности

Факты раскрытия ПДн третьим лицам должны быть зарегистрированы, включая то, какие ПДн были раскрыты, кому и в какое время.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

ПДн могут быть раскрыты в ходе нормальной работы. Такие факты раскрытия должны быть зарегистрированы (см. 12.4.1). Любые дополнительные факты раскрытия третьим лицам, такие как те, которые являются ре-

зультатом законных расследований или внешних аудитов, также должны быть зарегистрированы. Записи должны включать причину раскрытия и инстанцию, производящую раскрытие.

A.7 Точность и качество

Никакие дополнительные меры обеспечения ИБ не соответствуют данному правилу конфиденциальности.

A.8 Открытость, прозрачность и наблюдаемость

A.8.1 Раскрытие обработки персональных данных субподрядчиками

Мера обеспечения информационной безопасности

Привлечение обработчиком ПДн публичного облака для обработки ПДн субподрядчиков должно быть раскрыто до их привлечения соответствующим потребителям служб облачных вычислений.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В договоре между обработчиком ПДн публичного облака и потребителем служб облачных вычислений условия привлечения для обработки ПДн субподрядчиков должны быть прозрачны. Договор должен определять, что субподрядчики могут быть привлечены только на основе согласия, которое может обычно даваться потребителем служб облачных вычислений в начале использования служб. Обработчик ПДн публичного облака должен своевременно проинформировать потребителя служб облачных вычислений о любых намеченных в этом отношении изменениях таким образом, чтобы у потребителя служб облачных вычислений была возможность возразить против таких изменений или прекратить договор.

К раскрытой информации должна относиться информация о факте заключения субподрядного договора и именах соответствующих субподрядчиков, но никакие специфические детали об их бизнесе. Раскрытая информация должна также включать страны, в которых субподрядчики могут обработать данные в соответствии с A.12.1, и средства, с помощью которых субподрядчики обязаны выполнять или превышать обязательства обработчика ПДн публичного облака в соответствии с A.11.12.

Если публичное раскрытие информации субподрядчика оценено как увеличивающее угрозу безопасности выше приемлемых пределов, то раскрытие должно осуществляться в соответствии с соглашением о неразглашении и/или по запросу потребителя служб облачных вычислений. Потребитель служб облачных вычислений должен быть проинформирован, что информация доступна.

A.9 Индивидуальное участие и доступ

Никакие дополнительные меры обеспечения ИБ не соответствуют данному правилу конфиденциальности.

A.10 Подотчетность

A.10.1 Уведомление о компрометации данных, содержащих персональные данные

Мера обеспечения информационной безопасности

В случае любого несанкционированного доступа к ПДн или несанкционированного доступа к обрабатываемому их оборудованию или средствам, приведшего к потере, раскрытию или изменению ПДн, обработчик ПДн публичного облака должен сразу же уведомить соответствующего потребителя служб облачных вычислений.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Условия уведомления о компрометации данных, содержащих ПДн, должны быть частью договора между обработчиком ПДн публичного облака и потребителем служб облачных вычислений. Договор должен определять, как обработчик ПДн публичного облака будет предоставлять потребителю служб облачных вычислений информацию, необходимую для выполнения его обязательств по уведомлению соответствующих инстанций. Это обязательство по уведомлению не распространяется на компрометацию данных, вызванную потребителем служб облачных вычислений или субъектом ПДн или внутри компонентов систем, за которые они несут ответственность. Договор также должен определить максимально допустимую задержку при уведомлении о компрометации данных, содержащих ПДн.

Если произошла компрометация данных, содержащих ПДн, то должна сохраняться запись с описанием инцидента, его времени, последствий инцидента, имени сообщившего, кому об инциденте было сообщено, о предпринятых шагах по разрешению инцидента (включая ответственное лицо и восстановленные данные) и факта, что инцидент привел к потере, раскрытию или изменению ПДн.

Если произошла компрометация данных, содержащих ПДн, то запись должна также включать описание затронутых данных, если это известно; и если уведомление было осуществлено, то шагов, предпринятых для уведомления потребителя служб облачных вычислений и/или регулирующих органов.

В некоторых юрисдикциях соответствующие законы или нормы могут потребовать, чтобы обработчик ПДн публичного облака уведомил о компрометации данных, содержащих ПДн, непосредственно соответствующие регулирующие органы (например, инстанции по защите ПДн).

Примечание — Могут быть и другие не рассмотренные здесь нарушения, требующие уведомления, например сбор без согласия или другой авторизации, использование в несанкционированных целях и т. д.

A.10.2 Период хранения административной политики безопасности и руководств

Мера обеспечения информационной безопасности

Копии политики безопасности и операционных процедур должны храниться в течение указанного, документально зафиксированного времени до их замены (включая обновление).

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Может потребоваться пересмотр текущих и предыдущих политик и процедур, например, в случаях урегулирования споров потребителя и расследования инстанциями по защите ПДн. При отсутствии определенного правового или договорного требования минимальный рекомендуемый период хранения составляет пять лет.

A.10.3 Возврат, передача и удаление персональных данных

Мера обеспечения информационной безопасности

Обработчик ПДн публичного облака должен иметь политику возврата, передачи и/или удаления ПДн и должен предоставлять к этой политике доступ потребителю служб облачных вычислений.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В какой-то момент времени может потребоваться удалить ПДн некоторым способом, что может включать возврат ПДн потребителю служб облачных вычислений, их передачу другому обработчику ПДн публичного облака или оператору ПДн (например, в результате слияния), их надежное удаление или разрушение иным образом, анонимизирование или архивирование.

Обработчик ПДн публичного облака должен предоставить необходимую информацию, позволяющую потребителю служб облачных вычислений гарантировать, что обрабатываемые в соответствии с договором ПДн удалены (обработчиком ПДн публичного облака и любым из его субподрядчиков) из всех областей, где они хранились и использовались для резервного копирования и обеспечения непрерывности бизнеса, поскольку они больше не требуются потребителю служб облачных вычислений в определенных целях. Договором должны быть предусмотрены способы удаления (удаление связей, перезапись, размагничивание, разрушение или другие формы стирания) и/или применимые коммерческие стандарты.

Обработчик ПДн публичного облака должен разработать и проводить политику удаления ПДн и должен предоставлять к этой политике доступ потребителю служб облачных вычислений.

Для защиты потребителя служб облачных вычислений от потери ПДн при досрочном истечении договора политика должна распространяться на весь период хранения ПДн перед их удалением после прекращения договора.

Примечание — Эта мера обеспечения ИБ и рекомендации также имеют отношение к элементу хранения правила «Ограничение использования, сохранения и раскрытия» в соответствии с A.6.

A.11 Информационная безопасность поставщика

A.11.1 Соглашения о конфиденциальности или неразглашении

Мера обеспечения информационной безопасности

На пользователей, имеющих доступ к ПДн, находящимся под управлением обработчика ПДн публичного облака, должно распространяться обязательство о соблюдении конфиденциальности.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Соглашение о конфиденциальности, в любой форме, между обработчиком ПДн публичного облака, его работниками и агентами должно гарантировать, что работники и агенты не раскрывают ПДн в целях, не предусмотренных предписаниями потребителя служб облачных вычислений в соответствии с A.3.1. Обязательства соглашения о конфиденциальности должны соблюдаться и после завершения любого соответствующего договора.

A.11.2 Ограничение создания материалов на твердых копиях

Мера обеспечения информационной безопасности

Создание твердых копий материалов, отображающих ПДн, должно быть ограничено.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Твердые копии материалов включают в себя печатные материалы.

A.11.3 Управление и журналирование восстановления данных

Мера обеспечения информационной безопасности

Должны существовать процедура и журнал всех действий по восстановлению данных.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Примечание — Вышеприведенные меры обеспечения ИБ делают общим следующее требование, которое применяется в конкретных правовых юрисдикциях. Журнал действий по восстановлению данных должен содержать следующее: ответственное лицо, описание восстановленных данных и данные, которые были восстановлены вручную.

A.11.4 Защита данных на носителях, выносимых за пределы помещений организации**Мера обеспечения информационной безопасности**

ПДн на носителях, выносимых за пределы помещений организации, должны подвергаться процедуре авторизации и не должны быть доступны ни для кого, кроме авторизованного персонала (например, посредством шифрования названных данных).

A.11.5 Использование незашифрованных переносимых носителей и устройств**Мера обеспечения информационной безопасности**

Переносимые физические носители и портативные устройства, которые не поддерживают шифрование, не должны использоваться, кроме тех случаев, когда это неизбежно, а любое использование таких переносимых носителей и устройств должно быть документально зафиксировано.

A.11.6 Шифрование персональных данных, передаваемых по общедоступным сетям передачи данных**Мера обеспечения информационной безопасности**

ПДн, передаваемые по общедоступным сетям передачи данных, должны быть зашифрованы до их передачи.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В некоторых случаях, например при обмене электронной почтой, могут быть раскрыты присущие общедоступным сетевым системам передачи данных характеристики типа некоторых заголовков или данных трафика.

Если в предоставлении служб различных категорий служб эталонной архитектуры облачных вычислений вовлечено сразу много поставщиков, то роли по реализации данных рекомендаций могут изменяться или быть общими.

A.11.7 Безопасное уничтожение твердых копий материалов**Мера обеспечения информационной безопасности**

Твердые копии материалов должны быть уничтожены безопасным образом, используя такие механизмы, как перекрестная нарезка, измельчение, сожжение, превращение в мягкую массу и т. д.

A.11.8 Использование уникальных идентификаторов пользователей**Мера обеспечения информационной безопасности**

Если доступ к хранимым ПДн есть более чем у одного человека, то в целях идентификации, аутентификации и авторизации каждый из них должен иметь уникальный идентификатор пользователя.

A.11.9 Учет авторизованных пользователей**Мера обеспечения информационной безопасности**

Должен вестись актуальный учет пользователей или профилей пользователей, имеющих санкционированный доступ к информационной системе.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Для всех пользователей, чей доступ авторизован обработчиком ПДн публичного облака, должен поддерживаться профиль пользователя. Профиль пользователя содержит совокупность данных о пользователе, включая идентификатор пользователя, необходимый для реализации технических мер обеспечения ИБ, обеспечивающих санкционированный доступ к информационной системе.

A.11.10 Управление идентификаторами пользователей**Мера обеспечения информационной безопасности**

Деактивированные или истекшие идентификаторы пользователей не должны предоставляться другим людям.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

В контексте всей эталонной архитектуры облачных вычислений потребитель служб облачных вычислений

может нести ответственность за некоторые или все аспекты менеджмента идентификаторов пользователей для всех входящих в его зону управления пользователей служб облачных вычислений.

A.11.11 Меры, предусмотренные в договорах

Мера обеспечения информационной безопасности

Договоры между потребителем служб облачных вычислений и обработчиком ПДн публичного облака должны устанавливать минимально необходимые технические и организационные меры, гарантирующие, что зафиксированные в договорах меры защиты существуют и что данные не обрабатываются ни в каких иных целях, не предусмотренных в предписаниях потребителя. Такие меры не должны подвергаться сокращению обработчиком ПДн публичного облака в одностороннем порядке.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Обязательства по обеспечению ИБ и защите ПДн, касающиеся обработчика ПДн публичного облака, могут возникать непосредственно из действующего законодательства. Для иных случаев обязательства по защите ПДн, касающиеся обработчика ПДн публичного облака, должны быть отражены в договоре.

Меры обеспечения ИБ настоящего стандарта совместно с мерами обеспечения ИБ из ИСО/МЭК 27002 предназначены быть справочным каталогом мер, помогающим при заключении договора обработки информации в отношении ПДн. Обработчик ПДн публичного облака должен информировать предполагаемого потребителя служб облачных вычислений о вопросах защиты ПДн в его службах до заключения договора.

В процессе заключения договора обработчик ПДн публичного облака должен быть прозрачен с точки зрения предоставляемых им возможностей. Однако в конечном счете это obligation потребителя служб облачных вычислений — гарантировать, чтобы реализованные обработчиком ПДн публичного облака меры соответствовали заявленным обязательствам.

A.11.12 Обработка ПДн субподрядчиками

Мера обеспечения информационной безопасности

Договоры между обработчиком ПДн публичного облака и любыми субподрядчиками, обрабатывающими ПДн, должны устанавливать минимально необходимые технические и организационные меры, которые соответствуют заявленным обязательствам по обеспечению ИБ и защите ПДн обработчика ПДн публичного облака. Такие меры не должны подвергаться сокращению субподрядчиком в одностороннем порядке.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Меры обеспечения ИБ распространяются на привлечение для хранения резервных копий субподрядчиков в соответствии с A.8.1.

A.11.13 Доступ к данным в ранее использованной области памяти

Мера обеспечения информационной безопасности

Обработчик ПДн публичного облака должен гарантировать, что как только потребителю служб облачных вычислений будет выделена область памяти, любые ранее находившиеся в ней данные не станут доступны этому потребителю служб облачных вычислений.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Особенности исполнения операции удаления пользователем служб облачных вычислений данных, хранившихся в информационной системе, могут означать, что явное стирание таких данных технически неосуществимо. Это порождает риск считывания данных другим пользователем. Такого риска следует избегать, используя определенные технические меры.

Никакие специфические рекомендации по существу не подходят для учета всех случаев реализации этой меры обеспечения ИБ. Однако, в качестве примера, ряд облачных инфраструктур, платформ или приложений возвратят «нули», если пользователь служб облачных вычислений попытается считать область памяти, которая не была перезаписана собственными данными этого пользователя.

A.12 Соответствие условий обработки персональных данных законодательству

A.12.1 Географическое местоположение персональных данных

Мера обеспечения информационной безопасности

Обработчик ПДн публичного облака должен определить и документально зафиксировать страны, в которых могут храниться ПДн.

Рекомендации по реализации мер защиты персональных данных в публичных облаках

Идентичность (подлинность) стран, где могут храниться ПДн, должна быть доступна для потребителей служб облачных вычислений. Идентичность стран, возникающих при привлечении к обработке ПДн субподрядчиков,

должна быть включена. Если к трансграничной передаче данных применяются специфичные договорные соглашения, такие как соответствующие требования «типового контракта», «Корпоративные правила» или «Трансграничные правила в отношении персональных данных», то конкретные соглашения, страны или обстоятельства, при которых применяются такие соглашения, также должны быть определены явным образом. Обработчик ПДн публичного облака должен в срок, установленный в договоре, информировать потребителя служб облачных вычислений о любых намеченных в этом отношении изменениях, чтобы у потребителя служб облачных вычислений была возможность возразить против таких изменений или прекратить договор.

А.12.2 Намеченное место назначения персональных данных

Мера обеспечения информационной безопасности

На переданные с использованием сети передачи данных ПДн должны распространяться соответствующие меры обеспечения ИБ, предназначенные для обеспечения доставки данных до намеченного места назначения.

Приложение ДА
(справочное)

**Сведения о соответствии ссылочных международных
стандартов национальным и межгосударственным стандартам**

Таблица ДА.1

Обозначение ссылочного международного стандарта	Степень соответствия	Обозначение и наименование соответствующего национального, межгосударственного стандарта
ISO/IEC 17788	IDT	ГОСТ ISO/IEC 17788—2016 «Информационные технологии. Облачные вычисления. Общие положения и терминология»
ISO/IEC 27000	—	*
ISO/IEC 27002:2013	—	*
* Соответствующий национальный стандарт отсутствует. До его принятия рекомендуется использовать перевод на русский язык данного международного стандарта. Примечание — В настоящей таблице использовано следующее условное обозначение степени соответствия стандарта: - IDT — идентичный стандарт.		

Библиография

- [1] ISO/IEC 17789, Information technology — Cloud computing — Reference architecture
- [2] ISO/IEC 27001, Information technology — Security techniques — Information security management systems — Requirements
- [3] ISO/IEC 27005, Information technology — Security techniques — Information security risk management
- [4] ISO/IEC 27035, Information technology — Security techniques — Information security incident management
- [5] ISO/IEC 270364, Information technology — Security techniques — Information security for supplier relationships — Part 4: Guidelines for security of cloud services
- [6] ISO/IEC 27040, Information technology — Security techniques — Storage security
- [7] ISO/IEC 29100:2011, Information technology — Security techniques — Privacy framework
- [8] ISO/IEC 29101, Information technology — Security techniques — Privacy architecture framework
- [9] ISO/IEC 29134, Information technology — Security techniques — Guidelines for privacy impact assessment
- [10] ISO/IEC 29191, Information technology — Security techniques — Requirements for partially anonymous, partially unlinkable authentication
- [11] ISO/IEC JTC 1/SC 27, WG 5 Standing Document 2 — Part 1: Privacy References List. Latest version, available at <http://www.jtc1sc27.din.de/sbe/wg5sd2>
- [12] BS 10012:2009, Data protection. Specification for a personal information management system
- [13] JIS Q 15001:2006, Personal information protection management systems — Requirements
- [14] NIST SP 80053rev4, Security and Privacy Controls for Federal Information Systems and Organizations, April 2013 (<http://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>)
- [15] NIST SP 800122, Guide to Protecting the Confidentiality of Personally Identifiable Information (PII), April 2010 (<http://csrc.nist.gov/publications/nistpubs/800-122/sp800-122.pdf>)
- [16] NIST SP 800144, Guidelines on Security and Privacy in Public Cloud Computing, December 2011 (<http://csrc.nist.gov/publications/nistpubs/800-144/SP800-144.pdf>)
- [17] ENISA. Report on Cloud Computing: Benefits, risks and recommendations for information security, November 2009 (http://www.enisa.europa.eu/activities/risk-management/files/_deliverables/cloud-computing-risk-assessment/at_download/fullReport)
- [18] European Union, Article 29 Working Party. Opinion 05/2012 on Cloud Computing, adopted July 2012: (http://ec.europa.eu/justice/data-protection/article-29/documentation/opinionrecommendation/files/2012/wp196_en.pdf)

УДК 006.34:004.056:004.056.5:004.056.53:006.354

ОКС 35.030

Ключевые слова: персональные данные (ПДн), защита персональных данных, меры защиты ПДн, облачные вычисления, оператор ПДн, субъект ПДн, обработка ПДн

БЗ 12—2020

Редактор *Л.К. Одинцов*
Технический редактор *В.Н. Прусакова*
Корректор *В.Н. Прусакова*
Компьютерная верстка *А.Н. Золотаревой*

Сдано в набор 11.11.2020. Подписано в печать 01.12.2020. Формат 60 × 84^{1/8}. Гарнитура Ариал.
Усп. печ. л. 3,72. Уч.-изд. л. 3,34.
Подготовлено на основе электронной версии, предоставленной разработчиком стандарта

Создано в единичном исполнении во ФГУП «СТАНДАРТИНФОРМ»
для комплектования Федерального информационного фонда стандартов,
117418 Москва, Нахимовский пр-т, д. 31, к. 2.
www.gostinfo.ru info@gostinfo.ru